

Software Risk Assessment

Target: Booking.com Car Rental Section — New York (<https://www.booking.com/cars/index.html>) | Prepared: May 14, 2026

1. Risk Summary

This assessment evaluates the Booking.com car rental flow for the New York market, covering search, location selection (JFK / LGA / Newark / Manhattan offices), date-time selection, pricing, supplier integration, payment, and confirmation. The product is high-traffic, transactional, regulated (PCI-DSS, GDPR/CCPA, NY State consumer rules), and tightly coupled to multiple third-party rental suppliers. The risk profile is dominated by **product correctness** (pricing, availability, eligibility), **external dependencies** (supplier APIs), and **seasonal load** (summer / holiday peaks in NYC).

Out of 18 identified risks: **3 Critical, 9 High, 6 Medium, 0 Low**. Critical items are tied to inventory accuracy, pricing correctness, and pre-peak release pressure — they require executive owners and pre-launch sign-off.

2. Context

Business goal: drive car rental bookings in NYC with accurate, fast, and trustworthy search-to-confirmation flow.

Critical features: location search, date/time picker (DST aware), real-time availability and pricing, filters (car class, supplier, fuel policy), checkout with payment + 3DS, modification / cancellation.

Stakeholders: Product Owner, QA Lead, SRE, Payments, Legal, Partner Integration Lead, NY operations contact, Customer Support.

Constraints: multi-supplier dependencies; PCI-DSS and CCPA compliance; summer travel peak; non-English NY audience; mobile-first traffic share.

3. Risk Assessment Matrix

The matrix below maps Likelihood × Impact to an overall Risk Level. Every risk in the register is scored using this matrix.

	Impact: Low	Impact: Medium	Impact: High
Likelihood: High	Medium	High	Critical
Likelihood: Medium	Low	Medium	High
Likelihood: Low	Low	Low	Medium

4. Risk Register

Categories: **Product, Project, Process, Technical, External.**

ID	Category	Description	Likelihood	Impact	Risk Level	Owner	Mitigation Plan	Status
R-01	Product	Inaccurate availability of cars at NYC pickup locations (JFK, LGA, Manhattan offices) causing failed bookings.	High	High	Critical	Product Owner	Real-time inventory sync with rental partners (Hertz, Enterprise, Avis); fallback message + alternate location suggestions; circuit-breaker on stale feeds.	Open
R-02	Product	Incorrect price display (taxes, NY surcharges, airport fees, toll/EZ-Pass options) leading to user mistrust and chargebacks.	High	High	Critical	Pricing Team Lead	Pricing rule engine validation; automated regression on tax/fee scenarios; mandatory price-breakdown UI; daily reconciliation reports.	Open
R-03	Product	Date/time picker fails for cross-day rentals or DST transitions in America/New_York timezone.	Medium	High	High	Frontend Lead	Timezone-aware date library (e.g., Luxon); explicit unit + E2E tests for DST boundaries; server-side validation of pickup/return windows.	Open
R-04	Product	Driver age restrictions and young-driver surcharges in NY State not applied correctly (under 25 rules).	Medium	High	High	Business Analyst	Encode NY-specific eligibility rules; warning UI for age <25; partner API contract tests; legal review per quarter.	Open
R-05	Technical	Payment gateway failures or 3-D Secure (SCA) drop-offs during checkout.	Medium	High	High	Payments Engineer	Multi-PSP fallback (Stripe/Adyen); idempotent payment intent; retry with exponential backoff; alerting on conversion drops >5%.	Open
R-06	Technical	Search latency / timeouts when filtering NYC airport vs. city locations during peak hours.	High	Medium	High	Backend Tech Lead	Caching of location/inventory queries; CDN for static assets; load tests at 3x peak; autoscaling thresholds; graceful degradation.	Open
R-07	Technical	Map/geo widget (location picker) fails to load or shows wrong pin for NYC boroughs.	Medium	Medium	Medium	Frontend Lead	Provider redundancy (Google + fallback); geocoding accuracy tests; visual regression on map states; error boundary UI.	Open
R-08	Technical	Mobile responsiveness/accessibility issues on iOS Safari and Android Chrome reducing conversion.	Medium	Medium	Medium	QA Lead	Cross-browser/device matrix in test plan; WCAG 2.2 AA audit; Lighthouse and axe-core in CI; real-device cloud testing.	Open
R-09	Process	Incomplete test coverage for partner-supplier integrations (insurance add-ons, extras, prepay vs. pay-at-counter).	Medium	High	High	QA Lead	Contract testing (Pact) with each supplier; staging mocks; expand E2E suite to cover top 10 NY suppliers.	Open

ID	Category	Description	Likelihood	Impact	Risk Level	Owner	Mitigation Plan	Status
R-10	Process	Insufficient observability — no dashboards for funnel drop-off at NYC location step.	High	Medium	High	SRE / Analytics	Instrument funnel events; build Grafana/Datadog dashboards; weekly funnel review; alerting on anomalies.	Open
R-11	Project	Tight release timeline before NYC summer travel peak; risk of feature rush and regressions.	High	High	Critical	Project Manager	Feature flags for staged rollout; freeze window 2 weeks pre-peak; risk-based regression suite; go/no-go checklist.	Open
R-12	Project	Team knowledge silo on car-rental domain (taxes, insurance rules) — single SME.	Medium	Medium	Medium	Engineering Manager	Cross-training sessions; documentation in domain wiki; pair programming on critical flows.	Open
R-13	External	Third-party supplier API outages or breaking changes without notice.	Medium	High	High	Integration Lead	Supplier SLAs; contract tests in CI; circuit breaker + cached fallback inventory; supplier health dashboard.	Open
R-14	External	Regulatory changes in NY State (consumer protection, surcharges, fuel/cancellation rules).	Low	High	Medium	Legal / Compliance	Subscription to NY DMV/AG bulletins; quarterly legal review; configurable rule engine.	Open
R-15	External	Currency/FX edge cases for international travelers booking NYC rentals.	Medium	Medium	Medium	Payments Engineer	FX rate refresh job with monitoring; display original + converted price; reconciliation reports.	Open
R-16	Product	Cancellation/refund flow inconsistent between prepay and pay-at-pickup options.	Medium	High	High	Product Owner	Unified refund state machine; clear UI copy of cancellation policy; automated tests on refund branches.	Open
R-17	Technical	PII / payment data leakage via logs or analytics tooling (PCI-DSS / GDPR / CCPA exposure).	Low	High	High	Security Engineer	Log scrubbers; PII linter in CI; quarterly pen-test; tokenized payment fields; access reviews.	Open
R-18	Process	Localization issues for non-English NY users (Spanish, Mandarin, Russian) impacting trust and conversion.	Medium	Medium	Medium	Localization Lead	Translation QA pass; pseudo-localization tests; locale-aware date/number formats; UI screenshot diffs per locale.	Open

5. Test Scope Alignment

Test effort is allocated proportional to risk level. The table below maps risk areas to test types and coverage depth.

Risk Area	Test Types	Coverage Depth
Availability & Pricing (R-01, R-02, R-16)	E2E, contract tests, data validation, exploratory, regression	Exhaustive — every release + nightly
Date/Time & Eligibility (R-03, R-04)	Unit, boundary, E2E, manual exploratory on DST	High — pre-release + after timezone library upgrades
Payment & Checkout (R-05, R-17)	E2E, security (OWASP), PCI scope review, fault injection	Exhaustive — gated by security sign-off
Performance & Search (R-06, R-07)	Load, stress, soak, frontend perf (Lighthouse)	High — pre-peak load test at 3x expected
Cross-device / Accessibility (R-08, R-18)	Cross-browser, real-device, WCAG 2.2 AA, localization	Medium — release candidate phase
Supplier Integrations (R-09, R-13)	Contract (Pact), integration mocks, chaos tests	High — per-supplier + on contract change
Observability & Funnel (R-10)	Synthetic monitoring, analytics validation	Continuous — production
Release & Process (R-11, R-12)	Smoke, sanity, feature-flag rollout drills	High — every release
Compliance (R-14, R-17)	Static analysis, compliance review, log audits	Quarterly + on regulation change

6. Mitigation Strategy

6.1 Preventive Actions

- Adopt contract testing (Pact) with all NYC rental suppliers; fail CI on contract drift.
- Lock pricing rule engine behind code review + dedicated regression suite for taxes/fees.
- Enforce feature flags on every new flow; staged rollout (1% → 10% → 100%) for NYC traffic.
- Mandatory accessibility checks (axe-core, Lighthouse) in CI for the cars surface.
- PII linter in CI; scrubbers in shared logging library; quarterly access reviews.

6.2 Detective Actions

- Funnel dashboards (Grafana / Datadog) for NYC: search → location → checkout → confirm.
- Anomaly alerts on conversion drop > 5% or supplier error rate > 1%.
- Synthetic monitoring of the top 5 NYC flows every 5 minutes.

- Daily reconciliation: displayed price vs. supplier price vs. captured payment.
- Real-user monitoring (RUM) on mobile Safari / Chrome for Core Web Vitals.

6.3 Contingency Actions

- Circuit breaker + cached inventory fallback when a supplier API degrades.
- Multi-PSP routing: auto-failover from primary to secondary payment provider.
- Pre-approved rollback plan for every release; one-click feature-flag kill switch.
- On-call rotation with documented runbooks for top 10 NYC incident scenarios.
- Customer Support playbook for price/availability mismatches with goodwill voucher rules.

7. Recommendations & Next Steps

- Confirm explicit owners for every Critical and High risk before the next release gate.
- Schedule a load test at 3× expected peak NYC summer traffic no later than 4 weeks before peak.
- Run a tabletop incident exercise covering supplier outage + payment failure.
- Add a quarterly NY-State legal/compliance review to the engineering calendar.
- Refresh this risk register at every major release and after each Sev-1 incident.

Document prepared as part of the Software Risk Assessment project. All risks shown are Open and require review/sign-off by the listed owners.